

Rejestr ryzyk projektu Taskora					
Nazwa ryzyka	Typ ryzyka	Prawdopodobieństwo wystąpienia	Wpływ na projekt	Działania do podjęcia (rozwiązanie lub zmniejszenie ryzyka)	Ogólna ocena ryzyka
1. Awaria zewnętrznego serwera pocztowego SMTP	Zewnętrzne / Infrastrukturalne	Średnie	Wysoki (brak dostarczania powiadomień e-mail)	Zastosowanie asynchronicznych kolejek wiadomości (np. RabbitMQ) do buforowania powiadomień w tle do czasu przywrócenia usług serwera.	Średnia
2. Awaria zewnętrznych integracji (np. GitHub, CI/CD, Slack)	Zewnętrzne / Integracyjne	Średnie	Średni (brak automatycznych aktualizacji statusów)	Zapewnienie w pełni autonomicznego trybu działania (stand-alone), aby awarie usług trzecich nie zakłócały głównych procesów systemu.	Średnia
3. Nagły wzrost obciążenia i wyczerpanie zasobów serwera	Wydajnościowe / Infrastrukturalne	Wysokie	Wysoki (spadek wydajności i czas odpowiedzi powyżej 2 sekund)	Automatyczne skalowanie poziome architektury, uruchamiające dodatkowe węzły, gdy użycie CPU lub RAM przekracza 80% przez dłużej niż 5 minut.	Wysoka
4. Wyciek wrażliwych danych projektowych lub osobowych	Bezpieczeństwa / Prawne	Niskie	Krytyczny (naruszenie regulacji prawnych, np. RODO)	Szyfrowanie danych w spoczynku przy użyciu algorytmu AES-256, stosowanie mTLS w sieci wewnętrznej oraz trwała anonimizacja danych na żądanie użytkownika.	Wysoka
5. Przeciążenie bazy danych (RDBMS) dużą liczbą zapytań	Wydajnościowe	Średnie	Wysoki (spowolnienie generowania raportów i roadmap)	Wdrożenie replikacji klastrowej (Read Replicas) oraz użycie rozproszonej pamięci podręcznej (np. Redis) dla wyników najcięższych zapytań.	Średnia
6. Ataki typu DDoS lub masowe próby logowania Brute-Force	Bezpieczeństwa	Średnie	Wysoki (ryzyko zablokowania usług dla użytkowników)	Konfiguracja zapory aplikacyjnej (WAF), wdrożenie mechanizmów Rate Limiting w interfejsie API oraz czasowe blokowanie kont po nieudanych próbach logowania.	Wysoka
7. Niespójność danych w wyniku błędów zapisu złożonych obiektów	Technologiczne / Architektoniczne	Niskie	Wysoki (np. błędne przeniesienie zadania na tablicy Kanban)	Egzekwowanie mechanizmu transakcji zgodnych z ACID oraz użycie funkcji automatycznego wycofywania zmian (rollback) przy błędach operacji wieloetapowych.	Średnia
8. Krytyczna awaria głównego klastra bazy danych	Infrastrukturalne	Niskie	Krytyczny (całkowita utrata danych o realizowanych projektach)	Tworzenie zautomatyzowanych, pełnych kopii zapasowych bazy danych (backup) co najmniej raz na 12 godzin i przetrzymywanie ich w bezpiecznej lokalizacji przez minimum 30 dni.	Wysoka
9. Zawieszanie się interfejsu SPA przy renderowaniu dużych zbiorów zadań	Wydajnościowe / Interfejsu	Wysokie	Średni (spadek płynności obsługi list oraz roadmapy po stronie przeglądarki)	Wdrożenie systemowego mechanizmu paginacji oraz techniki leniwego ładowania (lazy loading) w celu odciążenia interfejsu przy dużej liczbie rekordów.	Średnia
10. Brak kompatybilności z przestarzałymi przeglądarkami użytkowników	Kompatybilności	Średnie	Średni (błędy renderowania i brak możliwości pracy metodą drag-and-drop)	Użycie metody "feature detection" z zabezpieczeniem zapasowym (fallback) oraz informowanie użytkownika o konieczności aktualizacji do dwóch najnowszych wersji przeglądarki.	Niska
11. Złamanie zabezpieczeń przez skuteczne ataki typu SQL Injection lub XSS	Bezpieczeństwa	Niskie	Krytyczny (kompromitacja systemu oraz danych klientów)	Restrykcyjna walidacja i sanityzacja danych wejściowych zgodnie ze standardami OWASP oraz obsługa Content Security Policy (CSP) w nagłówkach HTTP.	Wysoka
12. Niedostępność usługi zewnętrznego dostawcy tożsamości (SSO/IdP)	Zewnętrzne / Dostępności	Niskie	Wysoki (brak autoryzacji i możliwości zalogowania się)	Utrzymanie wbudowanego, alternatywnego systemu weryfikacji tożsamości z wymuszaniem logowania wieloskładnikowego (MFA) dla podwyższonych uprawnień.	Średnia
13. Niespełnianie standardów dostępności webowej (niezgodność z WCAG 2.1 AA)	Zgodności / Prawne	Niskie	Średni (trudności w obsłudze dla osób używających technologii asystujących)	Gwarancja dostępu do wszystkich operacji za pomocą klawiatury oraz poprawne oznakowanie semantyczne interfejsu (WAI-ARIA 1.2).	Niska
14. Niespodziewana utrata stabilnego połączenia internetowego po stronie klienta	Zewnętrzne / Środowiskowe	Wysokie	Niski (przerwanie płynnej pracy zespołu na interaktywnych tablicach)	Systemowe blokowanie wysyłania formularzy oraz wyświetlanie bardzo czytelnego komunikatu o braku sieci zamiast generowania nieoczekiwanych błędów.	Niska

15. Tworzenie nakładających się na siebie Sprintów w jednym zespole	Operacyjne / Procesowe	Średnie	Średni (konflikty w harmonogramie oraz zaburzenie statystyk velocity)	Wdrożenie systemowej weryfikacji i blokowania prób tworzenia Sprintów, których ramy czasowe nakładają się na siebie.	Średnia
16. Nieuprawniony dostęp do punktów końcowych API	Bezpieczeństwa	Niskie	Krytyczny (nieautoryzowana modyfikacja lub kradzież danych projektowych)	Opieranie architektury API na zasadzie minimalnych uprawnień (PoLP) oraz niezależna weryfikacja tokenu/roli dla każdego żądania.	Wysoka
17. Wyczerpanie przestrzeni dyskowej serwera przez pliki użytkowników	Infrastrukturalne / Skalowalności	Wysokie	Wysoki (zablokowanie działania aplikacji i błędy zapisu bazy danych)	Przechowywanie wszystkich wgrywanych załączników i dokumentów w zewnętrznej, skalowalnej usłudze Object Storage (np. S3) zamiast na dysku serwera.	Wysoka
18. Modyfikacja logów systemowych w celu zatarcia śladów ataku	Bezpieczeństwa / Zgodności	Niskie	Krytyczny (brak możliwości audytu oraz identyfikacji wektora włamania)	Automatyczne rejestrowanie logów w niejawnym dzienniku (Audit Trail) w sposób całkowicie uniemożliwiający ich modyfikację z poziomu aplikacji.	Średnia
19. Wykorzystanie komponentów open-source zawierających znane luki (CVE)	Technologiczne / Bezpieczeństwa	Średnie	Krytyczny (możliwość kompromitacji całego systemu przez znane wektory ataku)	Regularne skanowanie kodu i wdrożenie automatycznego blokowania aktualizacji na środowisko produkcyjne przy wykryciu podatności poziomu Critical lub High.	Wysoka
20. Przetwarzanie danych bez zgody po zmianie regulaminu lub polityki prywatności	Prawne / Zgodności	Średnie	Wysoki (ryzyko wysokich kar finansowych za naruszenie RODO)	Automatyczne blokowanie dostępu do głównych funkcji konta użytkownika do czasu wyraźnego zaakceptowania nowej wersji dokumentów prawnych.	Średnia

Legenda do Rejestru Ryzyk					
Kryterium	Skala	Uzasadnienie			
Prawdopodobieństwo wystąpienia	Wysokie	Zdarzenia bardzo prawdopodobne, zależne od nieprzewidywalnego zachowania środowiska lub użytkowników (np. nagłe skoki obciążenia, problemy z połączeniem).			
	Średnie	Typowe problemy techniczne i operacyjne występujące w projektach IT regularnie, ale nie na porządku dziennym (np. chwilowe awarie integracji zewnętrznych).			
	Niskie	Zdarzenia rzadkie, wymagające splotu wielu negatywnych czynników, przed którymi system jest już dobrze zabezpieczony na poziomie architektury.			
Wpływ na projekt	Krytyczny	Zdarzenia bezpośrednio zagrażające istnieniu projektu – kompromitacja systemu, całkowita utrata danych lub naruszenie regulacji prawnych (np. karalne naruszenie RODO).			
	Wysoki	Poważne naruszenie kluczowych wymagań SLA (dostępność poniżej zakładanego 99,9%), niedostępność głównych funkcji systemu lub znaczne przeciążenie serwerów.			
	Średni	Lokalne problemy utrudniające pracę, ale nie zatrzymujące całkowicie działania systemu (np. brak automatyzacji statusów, spadek płynności interfejsu).			
	Niski	Drobne, tymczasowe niedogodności dla pojedynczych użytkowników, które nie wpływają na globalny postęp prac zespołu.			
Ogólna ocena ryzyka	Wysoka	Ryzyka krytyczne dla projektu. Wymagają natychmiastowej uwagi, najwyższego priorytetu w planowaniu mechanizmów zabezpieczających oraz ciągłego monitorowania.			
	Średnia	Ryzyka ważne, które powinny być stale monitorowane. Działania zapobiegawcze i mitygujące muszą być uwzględnione w standardowym cyklu rozwoju projektu.			
	Niska	Ryzyka akceptowalne. Mają minimalny wpływ na projekt, są łatwe do opanowania i wymagają jedynie rutynowej kontroli ze strony zespołu.			